

WEB SECURITY ASSESSMENT

Lily Style — lilystyle.my.id
Authorized Web Application Security Assessment
Final Assessment — Non-Destructive Testing

1. Executive Summary

Assessment menemukan beberapa kelemahan keamanan. Temuan paling signifikan adalah SQL Injection pada parameter id di detail.php, dibuktikan dengan perubahan respons dan munculnya mysqli_sql_exception akibat input tanda kutip tunggal. Pengujian dihentikan sebelum ekstraksi atau manipulasi database.

Temuan lain mencakup pengungkapan versi PHP, konfigurasi atribut cookie session, verbose PHP error/path disclosure pada upload profil, security header yang belum terlihat, dan invalid product ID handling.

2. Scope & Rules of Engagement

Target: lilystyle.my.id

Jenis: Authorized Web Application Security Assessment

Metode: Non-destructive / low-impact testing

Area: Recon, endpoint, authentication/session, cart, profile, product detail, checkout

Batasan: Tidak melakukan DDoS, brute force, webshell, penghapusan data, atau ekstraksi database.

3. Methodology

Reconnaissance → Endpoint Mapping → HTTP/HTTPS Review → Authentication & Session Review → Input Validation → Security Configuration Review → Evidence Collection → Risk Assessment → Remediation.

4. Technical Findings

F-01 — SQL Injection pada detail.php?id

Severity: High (risk-based; dampak database penuh belum didemonstrasikan).

Evidence: detail.php?id=1 normal; id=1' menghasilkan respons jauh lebih kecil dan mysqli_sql_exception dengan SQL syntax error serta lokasi detail.php:8.

Recommendation: prepared statements, parameterized queries, validasi integer, dan internal error logging.

F-02 — PHP Version Disclosure

Severity: Low / Informational.

Evidence: X-Powered-By: PHP/8.4.23.

Recommendation: hilangkan X-Powered-By.

F-03 — Session Cookie Security Attributes

Severity: Low-Medium, perlu verifikasi.

Evidence: Set-Cookie yang diamati hanya menunjukkan PHPSESSID=REDACTED; path=/; atribut Secure, HttpOnly, SameSite tidak terlihat.

Recommendation: terapkan Secure, HttpOnly, SameSite sesuai kebutuhan. Tidak ada indikasi session fixation karena session ID sebelum/sesudah login berbeda.

F-04 — Verbose PHP Error & Path Disclosure

Severity: Low.

Evidence: upload JPEG benign memicu path `/var/www/html/linda/web/profile.php` dan warning `move_uploaded_file`.

Recommendation: matikan `display_errors` pada production dan log error secara internal.

F-05 — Security Headers Belum Terlihat

Severity: Low / Informational.

Recommendation: terapkan HSTS, CSP, X-Frame-Options/X-Frame-ancestors, X-Content-Type-Options, Referrer-Policy, dan Permissions-Policy sesuai kebutuhan.

F-06 — Invalid Product ID Handling

Severity: Informational / Low.

Recommendation: validasi integer positif dan gunakan 404 untuk produk yang tidak ditemukan.

5. Authentication & Authorization Observations

`update_cart_qty.php` melakukan pemeriksaan login dan mengembalikan Not logged in tanpa session.

`checkout.php` pada session yang diuji mengembalikan Login dulu. Tidak ditemukan bukti IDOR pada halaman pesanan yang diuji. Perilaku checkout dicatat sebagai observasi dan bukan vulnerability tanpa bukti bypass/dampak.

6. Risk Summary

F-01 SQL Injection — High — Confirmed input-to-query error

F-02 PHP version disclosure — Low/Info — Confirmed

F-03 Session cookie attributes — Low-Medium — Observed; verify

F-04 Verbose PHP error/path disclosure — Low — Confirmed

F-05 Security headers — Low/Info — Observed

F-06 Invalid product ID — Info/Low — Observed

7. Remediation Priority

1) Perbaiki SQL Injection dengan prepared statements dan validasi input.

2) Perbaiki konfigurasi session cookie.

3) Nonaktifkan verbose PHP errors dan perbaiki upload/error handling.

4) Tambahkan security headers dan perbaiki invalid ID handling.

8. Conclusion

Kelemahan input-to-query pada `detail.php?id` merupakan prioritas utama karena berpotensi berdampak pada kerahasiaan, integritas, dan ketersediaan data. Laporan ini tidak mengklaim database telah dikompromikan karena pengujian dihentikan sebelum ekstraksi/manipulasi data.

9. Evidence Notes

Evidence meliputi Nmap, HTTP/HTTPS headers, endpoint mapping, authentication response, `cart/update_cart_qty`, invalid product ID, SQL error pada `detail.php?id=1'`, dan verbose PHP error pada upload profil. PHPSESSID dan credential tidak dicantumkan.